

Security+ 2.4 · Cryptographic Attacks

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Cryptographic Attacks (9:31) · [vídeo original](#) · [YouTube](#)

Downgrade attack: convence as partes a usar protocolo FRACA (SSL strip: HTTPS→HTTP); hash collision (2 textos, mesmo hash — MD5 morreu por collision); brute force da chave. Defesa: HSTS (browser NUNCA aceita downgrade pra HTTP), patch crypto, algoritmo atual (TLS 1.3).

💡 Highlights que a prova cobra

- Downgrade: convence pra usar versão FRACA (SSL stripping)
- HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip
- Collision MD5/SHA-1: dois textos, mesmo hash — abandonados

🎯 Dicas de prova

- 'forces a connection to a weaker protocol' = downgrade attack
- 'prevents downgrade to HTTP' = HSTS

Cenário clássico: Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP (sem TLS)' = SSL stripping; defesa: HSTS.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. A forma correta de ARMAZENAR senhas de usuários:

- A) Hash com salt (ex: bcrypt)
- B) Criptografia AES reversível
- C) Texto claro protegido por firewall
- D) Base64

2. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

3. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Downgrade: convence pra usar versão FRACA (SSL stripping)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA (SSL stripping)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Collision MD5/SHA-1: dois textos, mesmo hash — abandonados'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Collision MD5/SHA-1: dois textos, mesmo hash — abandonados...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'forces a connection to a weaker protocol' = downgrade attack'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'forces a connection to a weaker protocol' = downgrade attack...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'prevents downgrade to HTTP' = HSTS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'prevents downgrade to HTTP' = HSTS...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP (sem TLS)' = SSL stripping; defesa: HSTS.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Downgrade: convence pra usar versão FRACA (SSL stripping)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA (SSL stripping)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cryptographic Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip...

GABARITO COMENTADO

- 1) A — Hash com salt (ex: bcrypt).** Senha se guarda como HASH salgado (bcrypt/argon2) — não reversível. Nunca em texto claro nem cripto reversível (a chave vaza junto).
- 2) B — É de mão única (não reversível).** Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade.
- 3) B — Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Downgrade: convence pra usar versão FRACA (SSL stripping). As demais alternativas configuram violações graves d
- 4) C — Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTP.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip. As demais alternativas configuram viola
- 5) C — Implementar a solução correspondente: Collision MD5/SHA-1: dois textos, mesmo ha.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Collision MD5/SHA-1: dois textos, mesmo hash — abandonados. As demais alternativas configuram violações graves
- 6) C — Implementar a solução correspondente: 'forces a connection to a weaker protocol'.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): 'forces a connection to a weaker protocol' = downgrade attack. As demais alternativas configuram violações grav
- 7) A — Implementar a solução correspondente: 'prevents downgrade to HTTP' = HSTS....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): 'prevents downgrade to HTTP' = HSTS. As demais alternativas configuram violações graves de conformidade ou falh
- 8) A — Implementar a solução correspondente: Cenário: 'atacante intercepta a primeira r.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Cenário: 'atacante intercepta a primeira requisição e devolve resposta HTTP (sem TLS)' = SSL stripping; defesa:
- 9) B — Implementar a solução correspondente: Downgrade: convence pra usar versão FRACA .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): Downgrade: convence pra usar versão FRACA (SSL stripping). As demais alternativas configuram violações graves d
- 10) D — Implementar a solução correspondente: HSTS: o browser SE lembra que o site é HTTP.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Cryptographic Attacks): HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip. As demais alternativas configuram viola

